AI agent security review checklist

Bring this checklist to the design review before an AI agent ships. An agent that reads untrusted content and can also take irreversible actions or send data out has a prompt injection path.

Agent _____ **Owner** _____ **Review date** _____

PART 1 Map the agent

1. What does it read?

List every source that enters the agent's context and mark each one trusted or untrusted. Trusted means only your team can write or change the content.

2. Whose authority does it act with?

Name every credential the agent holds and whose identity each credential represents.

3. What can it do?

List every action and sort the actions into read-only, reversible writes and irreversible writes (delete, send, pay, publish, merge, deploy).

4. How can data leave?

List every way information can get out: email, messages, web requests, rendered images or links, shared folders, pull requests.

PART 2 Documented

- ☐ Every input source, marked trusted or untrusted
- ☐ The credentials the agent holds and whose identity they represent
- ☐ Every action the agent can take, sorted by consequence
- ☐ Every way data can leave (email, links, images, outbound requests)

PART 3 Required before launch

- ☐ Credentials are scoped to the task, short-lived, and not the user's full identity
- ☐ A person approves every irreversible or outbound action, on a screen that shows exactly what will happen
- ☐ Images, links and outbound requests are limited to approved domains
- ☐ Untrusted content can't reach the component that takes consequential actions
- ☐ Every tool call is logged with the credential used and the content in context
- ☐ One tested step revokes the agent's access and stops it

PART 4 Decision

☐ **Ready to ship** ☐ **Not ready. Gaps to close:** _____

Product	Engineering	Security

Free to use and adapt. Courtney Root · courtneyroot.dev